

Módulo 3: Identidad y Control de Acceso

T08: IDOR y Control de Acceso

Carlos Rodríguez Contreras · GitHub: karrocon

 *Acceder a recursos de otros usuarios manipulando parámetros*

Objetivos

- Entender qué es IDOR (Insecure Direct Object Reference) y por qué es tan frecuente
- Explotar el endpoint de perfil de VulnApp para ver datos de otros usuarios
- Distinguir escalada horizontal (otro usuario) vs. vertical (otro rol)
- Implementar verificación de pertenencia de recursos en el servidor

En construcción

Este topic todavía no tiene slides completas.

Usa las diapositivas maestras (`slides-curso.html`) como referencia del contenido previsto.



Lab T08: IDOR en perfiles de usuario

Objetivo: acceder al perfil de otro usuario manipulando la URL

Setup: `cd VulnApp && npm start`

1. Inicia sesión como usuario 1 y navega a `GET /users/1`
2. Cambia el ID: `GET /users/2` — ¿puedes ver los datos del usuario 2?
3. Abre `src/routes/users.ts` y añade verificación: `req.user.id === userId`
4. Verifica que el acceso a otro perfil ahora devuelve 403